



Facultad de Ciencias

Búsqueda de factores RSA compartidos en los registros de Transparencia de Certificados: Un enfoque basado en el algoritmo Binary Tree Batch GCD

Finding shared RSA factors in the Certificate Transparency logs: A Binary Tree Batch GCD approach

Trabajo de fin de máster
para acceder al

**MÁSTER INTERUNIVERSITARIO (UC-UIMP) EN DATA
SCIENCE**

Autor: David Quinzaños Saiz
Codirector: Ana I. Gómez Pérez
Codirector: Domingo Gómez Pérez

Junio de 2026

Agradecimientos

Quiero aprovechar esta página para agradecer...

Resumen

palabras clave: RSA, batch GCD, Transparencia de Certificados, criptografía, ciberseguridad

En este Trabajo de Fin de Máster se estudia el problema de los factores compartidos en claves públicas RSA extraídas de *Certificate Transparency logs*. Esta vulnerabilidad puede aparecer cuando la generación de claves no se realiza con suficiente aleatoriedad, provocando que distintos módulos RSA compartan un mismo factor primo y puedan factorizarse de forma eficiente.

El trabajo se apoya, por un lado, en la tesis *Finding shared RSA factors in the Certificate Transparency logs*, que abordó este problema mediante un enfoque clásico de *batch GCD*, y, por otro, en el artículo de Pelofske, que propone el algoritmo *Binary Tree Batch GCD* como una alternativa más eficiente. A partir de estas referencias, se desarrolla una implementación propia en C++17 con GMP, se compara frente a las implementaciones Python originales del artículo y se prepara su aplicación sobre certificados reales extraídos de *CT logs*.

La evaluación experimental reproduce de forma reducida la estructura del experimento de Pelofske, utilizando módulos RSA de 1024 y 2048 bits, tres niveles de claves débiles y distintos tamaños de entrada. Los resultados confirman que el algoritmo *Binary Tree Batch GCD* mejora de forma consistente al método clásico basado en *remainder tree*, y muestran que la implementación C++/GMP reduce de manera significativa tanto el tiempo de ejecución como el consumo de memoria.

Además, el procedimiento se valida sobre una muestra real de certificados procedentes de *CT logs*. Tras filtrar las claves RSA y eliminar duplicados, se obtiene un conjunto de 601 módulos RSA únicos, con tamaños de 2048, 3072 y 4096 bits. Esta ejecución permite comprobar que el flujo completo de extracción, filtrado, normalización y análisis puede aplicarse correctamente a datos reales. En conjunto, el TFM combina estudio de trabajos previos, desarrollo algorítmico, implementación experimental y validación aplicada sobre un problema real de ciberseguridad.

Abstract

keywords: RSA, batch GCD, Certificate Transparency, cryptography, cybersecurity

This Master's Thesis studies the problem of shared factors in RSA public keys extracted from *Certificate Transparency logs*. This vulnerability may appear when key generation is not performed with sufficient randomness, causing different RSA moduli to share a prime factor and therefore become efficiently factorable.

The work builds, on the one hand, on the thesis *Finding shared RSA factors in the Certificate Transparency logs*, which addressed this problem using a classical *batch GCD* approach, and, on the other hand, on Pelofske's article, which proposes the *Binary Tree Batch GCD* algorithm as a more efficient alternative. Based on these references, we develop a C++17 implementation using GMP, compare it against the original Python implementations from the article, and prepare its application to real certificates extracted from *CT logs*.

The experimental evaluation reproduces, at a reduced scale, the structure of Pelofske's experiment, using 1024-bit and 2048-bit RSA moduli, three levels of weak keys, and several input sizes. The results confirm that *Binary Tree Batch GCD* consistently improves over the classical *remainder tree* approach, and show that the C++/GMP implementation significantly reduces both runtime and memory consumption.

In addition, the procedure is validated on a real-world sample of certificates obtained from *CT logs*. After filtering RSA keys and removing duplicates, the resulting dataset contains 601 unique RSA moduli, with sizes of 2048, 3072, and 4096 bits. This execution confirms that the complete workflow of extraction, filtering, normalization, and analysis can be applied correctly to real data. Overall, this thesis combines the study of previous work, algorithmic development, experimental implementation, and applied validation on a real cybersecurity problem.

Índice

1. Introducción	1
2. Fundamentos teóricos	3
2.1. Fundamentos de RSA	3
2.2. Máximo común divisor y su relación con RSA	4
2.3. Entropía y generación de claves RSA	5
2.4. Certificate Transparency logs	6
3. Estado del arte	9
3.1. Debilidades en la generación de claves RSA	9
3.2. Detección de factores compartidos en claves públicas RSA	10
3.3. Análisis masivo de claves débiles en Internet	11
3.4. Enfoque clásico basado en product tree y remainder tree	12
3.5. Limitaciones del método clásico	12
3.6. Binary Tree Batch GCD como propuesta reciente	13
3.7. Encaje y motivación del presente trabajo	14
4. Metodología y algoritmo propuesto	15
4.1. Fundamento del <i>batch GCD</i>	15
4.2. Algoritmo <i>Binary Tree Batch GCD</i>	17
4.3. Implementación desarrollada	18
5. Resultados y discusión	23
5.1. Configuración de la comparativa sintética	23
5.2. Validación funcional	24
5.3. Comparación de tiempos de ejecución	24
5.4. Comparación de consumo de memoria	25
5.5. Efecto del número de claves débiles	26
5.6. Aplicación a datos reales	27
5.7. Preparación de la campaña sobre <i>CT logs</i>	27
5.8. Discusión	28
6. Conclusiones y trabajo futuro	31
Referencias	33

Capítulo 1

Introducción

La necesidad de proteger la información y las comunicaciones ha existido desde hace siglos. Ya en la Antigüedad se empleaban métodos sencillos para dificultar la lectura de los mensajes por parte de terceros, y más adelante, durante la Segunda Guerra Mundial, máquinas como Enigma demostraron hasta qué punto la criptografía podía ser decisiva en contextos militares y estratégicos.

Sin embargo, todos estos métodos compartían una característica común: se trataba de sistemas de criptografía simétrica, es decir, emisor y receptor debían conocer previamente la misma clave secreta. Este enfoque puede funcionar en escenarios reducidos, pero plantea problemas evidentes cuando el número de usuarios crece. En el contexto actual, donde millones de personas se conectan continuamente a servicios en Internet, repartir de forma segura una misma clave entre todas las partes resulta inviable.

Para dar respuesta a este problema surgió la criptografía asimétrica, basada en el uso de dos claves relacionadas matemáticamente: una clave pública, que puede compartirse libremente, y una clave privada, que debe mantenerse en secreto [Rivest et al. \[1978\]](#). Gracias a este modelo, hoy es posible establecer comunicaciones seguras sin necesidad de haber intercambiado previamente una clave secreta. Además, la criptografía asimétrica permite no solo cifrar información, sino también autenticar identidades y firmar digitalmente mensajes, por lo que se ha convertido en una herramienta fundamental dentro de la seguridad informática.

Dentro de este ámbito, uno de los algoritmos más conocidos y utilizados históricamente ha sido RSA. Su seguridad se basa en la dificultad de factorizar números enteros grandes obtenidos como producto de dos números primos también grandes [Rivest et al. \[1978\]](#). En condiciones normales, esta dificultad hace que obtener la clave privada a partir de la clave pública resulte inviable en la práctica. Por ello, RSA ha ocupado durante muchos años un papel central dentro de la infraestructura de clave pública y de los certificados digitales utilizados en la Web.

No obstante, la seguridad de RSA no depende únicamente de su fundamento matemático, sino también de cómo se generan las claves en la práctica. Trabajos previos han mostrado que errores en este proceso pueden dar lugar a claves vulnerables, lo que convierte el análisis de implementaciones reales en una cuestión especialmente relevante desde el punto de vista de la ciberseguridad [Heninger et al. \[2012\]](#); [Pelofske \[2024\]](#); [Våge \[2022\]](#).

En este contexto, los *Certificate Transparency logs* o *CT logs* constituyen una fuente de información especialmente interesante, ya que permiten acceder a grandes volúmenes de certificados reales emitidos para sitios web. Esto los convierte en una base de datos muy valiosa para estudiar cómo se está desplegando realmente la criptografía en Internet y para detectar posibles debilidades en claves públicas utilizadas en la práctica [Våge \[2022\]](#).

La tesis en la que se apoya este trabajo, *Finding shared RSA factors in the Certificate Transpa-*

rency logs, mostró precisamente el interés de este enfoque y puso de manifiesto que todavía existe margen para seguir ampliando este tipo de análisis sobre conjuntos de datos aún mayores Våge [2022]. Por otro lado, el artículo de Pelofske propone el algoritmo *Binary Tree Batch GCD* como una alternativa más eficiente al enfoque clásico basado en *product tree* y *remainder tree* Pelofske [2024].

Partiendo de estas dos referencias, en este Trabajo de Fin de Máster seguiremos una estrategia en tres niveles. En primer lugar, reproduciremos de forma reducida la comparación experimental presentada en el artículo de Pelofske, con el fin de estudiar en un entorno controlado el comportamiento relativo del método clásico y del algoritmo *Binary Tree Batch GCD*. En segundo lugar, desarrollaremos una implementación propia en C++17 orientada a ejecutar este algoritmo de forma más eficiente sobre módulos RSA reales. Por último, conectaremos esa implementación con el objetivo aplicado del trabajo: analizar certificados extraídos de *CT logs* mediante el nuevo algoritmo, dejando preparada la ejecución para conjuntos mayores en un entorno de cómputo como Altamira.

De este modo, el trabajo no se limitará únicamente a revisar una propuesta reciente desde el punto de vista teórico, sino que combinará reproducción experimental, desarrollo algorítmico e implementación aplicada. La comparativa sintética servirá para justificar que el algoritmo elegido mejora al enfoque clásico y para comprobar que nuestra implementación produce resultados compatibles con las versiones de referencia. La parte aplicada, en cambio, estará orientada a preparar el ataque *batch GCD* sobre certificados reales procedentes de *Certificate Transparency*, primero mediante una muestra local y después mediante el conjunto completo destinado a ejecutarse en un entorno de cómputo como Altamira.

Desde el punto de vista de la ciberseguridad, este trabajo resulta relevante por varios motivos. Por un lado, nos permitirá estudiar una vulnerabilidad concreta pero con consecuencias graves, ya que una mala generación de claves puede comprometer completamente la seguridad de RSA. Por otro, nos situará en un escenario de análisis aplicado sobre datos reales, algo especialmente valioso en un ámbito donde no basta con que los algoritmos sean seguros en teoría, sino que también deben comportarse correctamente en la práctica.

En este Trabajo de Fin de Máster estudiaremos el problema de la detección de claves RSA vulnerables a partir del análisis de certificados publicados en *Certificate Transparency logs*, tomando como punto de partida una tesis previa y apoyándonos en un algoritmo más reciente y eficiente. A lo largo del documento presentaremos primero los fundamentos teóricos necesarios, revisaremos después el estado del arte, describiremos la metodología seguida, expondremos los resultados obtenidos sobre datos sintéticos y reales, y finalmente discutiremos las principales conclusiones y el despliegue previsto sobre el conjunto completo de certificados en Altamira.

Capítulo 2

Fundamentos teóricos

En este capítulo presentaremos los conceptos teóricos necesarios para comprender el problema abordado en este Trabajo de Fin de Máster. Dado que nuestro objetivo es estudiar la detección de factores compartidos en claves RSA extraídas de *Certificate Transparency logs*, consideramos que los cuatro elementos fundamentales que es necesario introducir previamente son el funcionamiento general de RSA, el papel del máximo común divisor en este contexto, la importancia de la entropía durante la generación de claves y, por último, la utilidad de los *CT logs* como fuente de datos para este tipo de análisis.

No se pretende realizar aquí una exposición exhaustiva de toda la teoría criptográfica relacionada con la Web, sino presentar únicamente aquellos conceptos que resultarán necesarios para entender el desarrollo posterior del trabajo. De este modo, en los capítulos siguientes podremos centrarnos con más claridad en los trabajos previos, en la metodología empleada y en la implementación del algoritmo utilizado.

2.1. Fundamentos de RSA

RSA es uno de los algoritmos más conocidos de criptografía asimétrica y uno de los más influyentes en la historia de la seguridad informática [Rivest et al. \[1978\]](#). A diferencia de la criptografía simétrica, donde emisor y receptor comparten la misma clave secreta, en criptografía asimétrica cada usuario dispone de un par de claves relacionadas matemáticamente: una clave pública, que puede compartirse libremente, y una clave privada, que debe mantenerse en secreto.

Este modelo permitió resolver uno de los grandes problemas de la criptografía clásica, que era el intercambio seguro de claves en entornos abiertos. Gracias a ello, hoy es posible establecer comunicaciones seguras, autenticar identidades y firmar digitalmente información sin necesidad de que las partes hayan compartido previamente un secreto común [Rivest et al. \[1978\]](#).

En el caso de RSA, la seguridad del sistema se basa en la dificultad de factorizar un número entero grande obtenido como producto de dos números primos también grandes. Si denotamos estos primos por p y q , el módulo RSA se construye como

$$N = p \cdot q$$

A partir de estos valores se calcula también la función de Euler

$$\varphi(N) = (p - 1)(q - 1)$$

Después se elige un exponente público e , coprimo con $\varphi(N)$, y se calcula el exponente privado d como el inverso multiplicativo de e módulo $\varphi(N)$, de manera que

$$e \cdot d \equiv 1 \pmod{\varphi(N)}$$

De este modo, la clave pública queda formada por el par (N, e) , mientras que la clave privada contiene la información necesaria para conocer d , directamente o a través de la factorización del módulo. En una versión simplificada del esquema, el cifrado de un mensaje m se realiza mediante

$$c \equiv m^e \pmod{N}$$

y el descifrado mediante

$$m \equiv c^d \pmod{N}$$

La fortaleza de RSA se apoya, por tanto, en que multiplicar dos primos grandes es sencillo, mientras que recuperar esos primos a partir únicamente de N es un problema computacionalmente muy costoso en condiciones normales Rivest et al. [1978]. Por este motivo, RSA ha sido durante muchos años uno de los algoritmos más utilizados en certificados digitales y en infraestructuras de clave pública dentro de la Web.

Sin embargo, esta seguridad práctica no depende únicamente de la dificultad general del problema de factorización. También depende de que los primos p y q se hayan generado correctamente, sean suficientemente grandes y, sobre todo, sean independientes de los utilizados por otras claves. Esta última idea será especialmente importante en este trabajo, ya que la presencia de factores compartidos entre módulos RSA supone una debilidad crítica que permite comprometer la seguridad del sistema sin necesidad de resolver el problema general de factorización.

2.2. Máximo común divisor y su relación con RSA

El máximo común divisor, o *Greatest Common Divisor* (GCD), de dos enteros es el mayor número que divide exactamente a ambos. Se trata de un concepto básico de teoría de números, pero en el contexto de RSA adquiere una importancia especial, ya que permite detectar de manera muy eficiente si dos módulos comparten algún factor primo.

Si consideramos dos módulos RSA distintos

$$N_1 = p \cdot q_1$$

y

$$N_2 = p \cdot q_2,$$

entonces ambos comparten el factor primo p . En ese caso, basta calcular

$$\gcd(N_1, N_2) = p$$

para recuperar directamente ese factor común. Una vez conocido, la factorización de ambos módulos resulta inmediata y, con ello, también la reconstrucción de la información necesaria para comprometer las claves privadas asociadas. Por tanto, dos claves RSA que compartan un factor dejan de ser seguras de forma prácticamente instantánea.

El interés del GCD en este trabajo no está solo en esta propiedad, sino también en que puede calcularse de forma muy eficiente mediante el algoritmo de Euclides. Este algoritmo se basa en una idea sencilla: el máximo común divisor de dos números no cambia si sustituimos el mayor por el resto de dividirlo entre el menor. Repitiendo este proceso de manera sucesiva se llega rápidamente a un resto cero, y el último resto no nulo es precisamente el máximo común divisor.

De forma simplificada, si $a > b$, el algoritmo aplica la relación

$$\gcd(a, b) = \gcd(b, a \bmod b)$$

hasta alcanzar el caso final en el que el resto es cero. La eficiencia de este procedimiento es una de las razones por las que los ataques basados en GCD son tan potentes cuando existen factores compartidos entre claves RSA.

En el contexto de este TFM, el máximo común divisor desempeña un doble papel. Por un lado, constituye la herramienta matemática que permite explotar la debilidad cuando existen factores compartidos entre módulos RSA. Por otro, se convierte en la operación central de los algoritmos diseñados para detectar este problema a gran escala.

2.3. Entropía y generación de claves RSA

Aunque RSA es un esquema sólido desde el punto de vista matemático, su seguridad práctica depende de que la generación de claves se realice correctamente. En particular, para construir una clave RSA segura es necesario que los números primos p y q se generen de manera suficientemente aleatoria e independiente. Si esta condición no se cumple, pueden aparecer relaciones inesperadas entre distintas claves públicas, incluyendo la reutilización accidental de factores primos [Heninger et al. \[2012\]](#); [Pelofske \[2024\]](#); [Våge \[2022\]](#).

En este contexto, la entropía hace referencia al grado de imprevisibilidad disponible en el sistema para alimentar el proceso de generación aleatoria. En un entorno bien diseñado, esa entropía permite producir candidatos a primos que sean efectivamente impredecibles. Sin embargo, en sistemas reales esto no siempre ocurre. Tal y como señalan tanto la tesis de Våge como el artículo de Pelofske, una baja entropía durante la fase de generación de primos puede hacer que distintas claves RSA compartan factores, lo que compromete completamente su seguridad [Pelofske \[2024\]](#); [Våge \[2022\]](#).

Esta situación puede deberse a varias causas. Entre ellas se encuentran el uso incorrecto de librerías de generación aleatoria, errores de implementación o la falta de una fuente externa suficiente de entropía en el momento de generar la clave [Pelofske \[2024\]](#). Este problema resulta especialmente preocupante en dispositivos con recursos limitados, sistemas embebidos o equipos que generan claves en condiciones poco favorables, por ejemplo justo después del arranque.

La tesis en la que se apoya este trabajo subraya que, en condiciones ideales, la probabilidad de que dos claves RSA distintas reutilicen un mismo primo dentro del enorme espacio de posibles primos de tamaño criptográfico es prácticamente nula [Våge \[2022\]](#). Por eso, cuando en la práctica aparecen factores compartidos entre módulos públicos, no estamos ante una simple casualidad matemática, sino ante una señal muy clara de que ha existido un fallo en el proceso de generación.

Además, este problema no es meramente teórico. Trabajos previos ya mostraron que la baja entropía y otros errores de implementación podían dar lugar a claves públicas vulnerables en sistemas reales, incluyendo dispositivos conectados a Internet [Heninger et al. \[2012\]](#). La tesis de Våge retoma esta línea

de investigación aplicándola al análisis de certificados publicados en *CT logs*, mientras que el artículo de Pelofske plantea un algoritmo más eficiente precisamente para atacar este tipo de situaciones a gran escala Pelofske [2024]; Våge [2022].

Por tanto, la importancia de la entropía en este TFM es doble. Por un lado, explica el origen de la vulnerabilidad que queremos estudiar. Por otro, justifica por qué tiene sentido analizar grandes volúmenes de claves públicas reales en busca de factores compartidos. Si la generación de claves no se realiza siempre en condiciones ideales, entonces la auditoría empírica de la infraestructura criptográfica desplegada en Internet se convierte en una tarea especialmente relevante desde el punto de vista de la ciberseguridad.

2.4. Certificate Transparency logs

Para poder estudiar este problema en sistemas reales es necesario contar con una fuente amplia y accesible de claves públicas. En este trabajo esa fuente serán los *Certificate Transparency logs*, o *CT logs*, que almacenan certificados digitales emitidos para dominios y servicios de Internet.

Antes de explicar su utilidad, conviene recordar brevemente qué papel desempeñan los certificados digitales en la Web. Un certificado digital es un documento electrónico, normalmente en formato X.509, que vincula una clave pública con una determinada identidad o dominio. Estos certificados son emitidos por autoridades certificadoras dentro de la infraestructura de clave pública, o *Public Key Infrastructure* (PKI), y permiten que un navegador u otro cliente verifique que la clave pública presentada por un servidor pertenece realmente a la entidad con la que dice comunicarse.

En la práctica, este mecanismo es uno de los pilares de protocolos como TLS, utilizados para proteger las comunicaciones mediante HTTPS. Cuando un usuario accede a una página web segura, el servidor presenta su certificado y, con él, la clave pública asociada. De este modo, los certificados digitales no solo hacen posible la autenticación de servidores, sino que también exponen públicamente una gran cantidad de claves que pueden ser analizadas con fines de auditoría criptográfica.

En este contexto surge *Certificate Transparency*, un marco diseñado para aportar mayor transparencia al ecosistema de certificación web. Su idea principal es que los certificados emitidos por las autoridades certificadoras queden registrados en logs públicos y verificables, de manera que su emisión pueda ser observada y supervisada por terceros. Esto dificulta que una autoridad certificadora emita certificados incorrectos o fraudulentos sin que nadie pueda detectarlo.

Desde el punto de vista de nuestro trabajo, la importancia de *Certificate Transparency* está en que estos logs contienen enormes volúmenes de certificados reales emitidos en Internet. Como los certificados incluyen las claves públicas de los servidores, los *CT logs* se convierten en una base de datos muy valiosa para estudiar cómo se está desplegando realmente la criptografía en la Web y para realizar auditorías a gran escala sobre claves públicas RSA.

La tesis *Finding shared RSA factors in the Certificate Transparency logs* demostró precisamente el interés de este enfoque Våge [2022]. En ese trabajo se recopilaban más de 159 millones de claves RSA distintas de 2048 bits extraídas de *CT logs*, lo que permitió detectar casos reales de factores compartidos y mostró que este tipo de análisis es viable sobre conjuntos masivos de certificados Våge [2022]. Al mismo tiempo, la propia tesis dejaba claro que todavía quedaba margen para ampliar este tipo de estudios sobre volúmenes aún mayores de datos.

Esto conecta de forma directa con la línea de trabajo seguida en este TFM. Gracias a los *CT logs*

es posible pasar de un análisis puramente teórico sobre debilidades de RSA a una auditoría empírica sobre claves públicas realmente desplegadas en Internet. Como veremos en el capítulo siguiente, esta posibilidad ha dado lugar a trabajos previos muy relevantes y justifica la necesidad de seguir buscando métodos más eficientes para detectar factores compartidos a gran escala.

Capítulo 3

Estado del arte

Tras haber presentado los conceptos necesarios para entender este trabajo, en este capítulo revisaremos los principales antecedentes relacionados con el problema que abordamos en este Trabajo de Fin de Máster.

En particular, nos centraremos en cómo la literatura ha estudiado las debilidades en la generación de claves RSA, la detección de factores compartidos entre claves públicas y el análisis de este tipo de vulnerabilidades sobre grandes conjuntos de datos reales.

Además, revisaremos los enfoques clásicos utilizados hasta ahora, sus principales limitaciones y la propuesta más reciente en la que se apoya este trabajo, con el fin de situar con claridad nuestra aportación dentro de la literatura previa.

3.1. Debilidades en la generación de claves RSA

Como ya hemos explicado en el capítulo anterior, la seguridad práctica de RSA depende en gran medida de que la generación de claves se realice correctamente. Por ello, una de las líneas más importantes dentro de la literatura ha consistido en analizar hasta qué punto problemas de baja entropía o fallos de implementación pueden dar lugar a claves vulnerables en sistemas reales.

Uno de los trabajos más influyentes en esta dirección fue el de Heninger et al., que mostró que la existencia de claves débiles no era una posibilidad puramente teórica, sino un problema que podía observarse en dispositivos conectados a Internet [Heninger et al. \[2012\]](#). A partir de este tipo de estudios quedó claro que, aunque RSA siga siendo un esquema robusto desde el punto de vista matemático, su seguridad puede verse comprometida si la generación de claves no dispone de suficiente aleatoriedad o si se emplean implementaciones defectuosas.

Esta misma idea aparece también de forma clara tanto en la tesis de Våge como en el artículo de Pelofske. En ambos casos se insiste en que una de las debilidades más relevantes de RSA no se encuentra en el algoritmo en sí, sino en la fase de creación de los primos. En particular, Pelofske señala que estos fallos pueden deberse a un uso incorrecto de librerías de generación aleatoria o a la ausencia de una fuente externa de entropía suficiente en el momento de generar la clave [Pelofske \[2024\]](#). Cuando esto sucede, distintas claves pueden terminar compartiendo factores primos, lo que las vuelve inmediatamente vulnerables.

La tesis de Våge refuerza esta idea al recordar que, en condiciones ideales, la probabilidad de que dos claves RSA distintas reutilicen un mismo primo dentro del enorme espacio de posibles primos criptográficos es prácticamente nula [Våge \[2022\]](#). Por ello, cuando este fenómeno aparece en la prác-

tica, no estamos ante una simple coincidencia matemática, sino ante una evidencia clara de que el proceso de generación de claves ha fallado de alguna manera.

Desde el punto de vista del estado del arte, esto resulta especialmente importante porque justifica toda una línea de trabajos orientados a auditar claves públicas reales en busca de este tipo de debilidades. En otras palabras, el interés de la literatura no ha estado en cuestionar la validez teórica de RSA, sino en estudiar si las implementaciones reales respetan las condiciones necesarias para que esa seguridad teórica se mantenga en la práctica.

En este sentido, tanto la tesis como el artículo que sirven de base a este TFM parten de una misma premisa: la baja entropía y los errores de implementación pueden dar lugar a factores compartidos entre módulos RSA, y esos factores compartidos constituyen una vulnerabilidad grave que merece ser analizada empíricamente a gran escala [Pelofske \[2024\]](#); [Våge \[2022\]](#). A partir de aquí, el siguiente paso natural dentro de la literatura fue centrarse en cómo detectar de forma eficiente esas claves vulnerables.

3.2. Detección de factores compartidos en claves públicas RSA

Una vez asumido que pueden existir fallos reales en la generación de claves RSA, el siguiente problema que pasó a ocupar a la literatura fue cómo detectar esas debilidades de forma efectiva. En este contexto, la presencia de factores compartidos entre módulos públicos se convirtió rápidamente en un objetivo de estudio especialmente relevante, ya que permite identificar claves vulnerables de manera directa.

Los trabajos previos mostraron que, cuando dos módulos RSA comparten un factor primo, su factorización deja de ser un problema difícil en la práctica. Por ello, la cuestión dejó de ser únicamente si este fenómeno podía ocurrir y pasó a centrarse en cómo encontrar esos casos dentro de grandes colecciones de claves públicas reales. Esta transición, desde la vulnerabilidad conceptual hasta su detección empírica, marcó una parte importante del desarrollo posterior de esta línea de investigación [Heninger et al. \[2012\]](#); [Våge \[2022\]](#).

Tal y como plantea Pelofske, el verdadero problema no está en calcular el máximo común divisor entre dos módulos concretos, ya que esa operación es eficiente, sino en que no se conoce de antemano qué pares de claves podrían compartir factores [Pelofske \[2024\]](#). Esto hace que una búsqueda exhaustiva basada en comparar todos los pares posibles se vuelva rápidamente inviable cuando el número de módulos crece. En conjuntos grandes de claves públicas, el número de comparaciones necesarias aumenta de forma cuadrática, lo que convierte el enfoque ingenuo en una opción poco realista para auditorías a gran escala.

Precisamente por esta razón, la literatura comenzó a desarrollar métodos específicos para realizar este tipo de análisis de manera más eficiente. En lugar de tratar cada comparación de forma aislada, estos enfoques buscan explotar la estructura global del conjunto de módulos RSA para detectar divisores comunes no triviales con un coste mucho menor que el de una enumeración completa de todos los pares. Esta es la idea general que dará lugar a los distintos enfoques de *batch GCD*, que más adelante explicaremos con mayor detalle.

La tesis de Våge se sitúa claramente dentro de esta línea, ya que toma como punto de partida el problema de detectar factores compartidos en grandes colecciones de claves RSA extraídas de *CT logs* y aplica para ello un enfoque basado en *batch GCD* [Våge \[2022\]](#). Por su parte, el artículo de Pelofske parte del mismo problema de detección masiva, pero propone una alternativa más eficiente al método clásico utilizado hasta ahora [Pelofske \[2024\]](#).

Así, dentro del estado del arte, la detección de factores compartidos en claves públicas RSA debe entenderse no solo como una consecuencia natural de las debilidades en la generación de claves, sino también como un problema computacional en sí mismo. Es precisamente esa doble dimensión, criptográfica por un lado y algorítmica por otro, la que explica el interés que ha despertado este tema en la literatura reciente.

A partir de ahí, el siguiente paso fue llevar este tipo de análisis a conjuntos de datos cada vez mayores, con el objetivo de comprobar hasta qué punto estas debilidades aparecían realmente en sistemas desplegados en Internet.

3.3. Análisis masivo de claves débiles en Internet

Una vez planteado el problema de detectar factores compartidos entre claves públicas RSA, la siguiente evolución natural dentro de la literatura fue trasladar este análisis a conjuntos de datos cada vez mayores. El interés dejó de centrarse únicamente en demostrar que la vulnerabilidad era posible y pasó a orientarse hacia auditorías criptográficas a gran escala, con el objetivo de comprobar hasta qué punto estas debilidades aparecían realmente en sistemas desplegados en Internet.

En este contexto, uno de los trabajos más relevantes fue el de Heninger et al., que realizó un escaneo masivo de servicios accesibles en Internet y recopiló millones de claves públicas RSA procedentes principalmente de HTTPS y SSH [Heninger et al. \[2012\]](#). Sus resultados mostraron que era posible factorizar un número significativo de estas claves, lo que confirmó que el problema no era anecdótico y que existían implementaciones reales vulnerables debido a deficiencias en la generación de claves.

A partir de ahí, otros trabajos ampliaron tanto el volumen analizado como el número de claves factorizadas. Tal y como resume la tesis de Våge, estudios posteriores llegaron a recopilar decenas de millones de claves RSA y a factorizar cientos de miles de ellas [Våge \[2022\]](#). En particular, la propia tesis recoge que Hastings et al. analizaron 81 millones de claves y factorizaron más de 313.000, mientras que Kilgallin et al. analizaron unos 57 millones de claves procedentes de escaneos de Internet y lograron factorizar 249.548 [Våge \[2022\]](#).

Estos resultados muestran que la búsqueda de factores compartidos dejó de ser rápidamente un problema puramente académico para convertirse en una herramienta útil de auditoría sobre infraestructuras reales. Además, la literatura comenzó a señalar que el auge del Internet de las Cosas podía estar relacionado con la persistencia de este tipo de vulnerabilidades, ya que muchos de estos dispositivos son ligeros, disponen de pocos recursos y pueden contar con fuentes de entropía pobres [Våge \[2022\]](#).

Sin embargo, el origen de las claves analizadas también resultó ser un aspecto importante. La tesis de Våge destaca que existe una diferencia relevante entre las claves obtenidas mediante escaneos de Internet y las procedentes de certificados publicados en *Certificate Transparency logs* [Våge \[2022\]](#). Mientras que los escaneos pueden devolver certificados autofirmados, de prueba o de uso interno, las claves presentes en *CT logs* están asociadas a certificados firmados por autoridades certificadoras reconocidas por los principales navegadores. Esto hace que los *CT logs* resulten especialmente interesantes cuando el objetivo es estudiar la criptografía realmente desplegada en el ecosistema web público.

La tesis que sirve de base a este TFM se sitúa precisamente en esta línea. Frente a trabajos anteriores más centrados en escaneos de Internet, Våge recopiló 159.377.664 claves RSA distintas de 2048 bits extraídas de *CT logs*, lo que, según indica, constituye el mayor conjunto de este tipo utilizado hasta ese momento para comprobar la existencia de factores compartidos [Våge \[2022\]](#). En la ejecución general del algoritmo se encontraron ocho claves vulnerables, todas ellas emitidas por ZeroSSL, y un análisis posterior centrado en esta autoridad certificadora permitió factorizar 355 claves únicas dentro de un conjunto de más de 700.000 [Våge \[2022\]](#).

Además, la conclusión de la tesis resulta especialmente relevante para nuestro trabajo, ya que señala que tanto ese estudio como el de Kilgallin et al. apenas habían analizado una pequeña fracción del volumen total de certificados subidos a los *CT logs* desde 2013 Våge [2022]. Esto pone de manifiesto que el problema seguía lejos de estar agotado y que todavía existía margen para investigaciones más grandes y exhaustivas. Precisamente en ese punto cobra importancia la necesidad de contar con algoritmos cada vez más eficientes para detectar factores compartidos a gran escala.

3.4. Enfoque clásico basado en *product tree* y *remainder tree*

Para que este tipo de análisis masivo sea viable, la literatura tuvo que ir más allá de la comparación ingenua entre todos los pares posibles de módulos RSA. Como ya se ha comentado, una estrategia basada en calcular el GCD de cada par crece de forma cuadrática y se vuelve poco realista cuando el número de claves es muy grande. Por ello, se desarrollaron algoritmos específicos capaces de explotar la estructura del conjunto completo de módulos para reducir de forma importante el coste del análisis.

Dentro de estos enfoques, el método clásico que ha acabado consolidándose es el basado en la construcción de un *product tree* seguido de un *remainder tree*. Tanto la tesis de Våge como el artículo de Pelofske lo presentan como la referencia principal frente a la que se comparan las propuestas más recientes Pelofske [2024]; Våge [2022].

La idea general de este enfoque consiste en multiplicar de forma jerárquica todos los módulos RSA del conjunto para construir un árbol de productos. Después, a partir de esa estructura, se calcula un árbol de residuos que permite determinar, en las hojas, si un módulo comparte algún factor con el producto del resto Pelofske [2024]. De esta forma, no es necesario comparar cada clave con todas las demás de manera independiente, sino que el problema se reorganiza mediante operaciones sobre árboles que aprovechan mejor la estructura global del conjunto.

La tesis de Våge explica además cómo este método puede adaptarse a ejecuciones de gran escala dividiendo la colección completa de módulos en varios lotes o *batches* Våge [2022]. Para cada lote se construye su correspondiente *product tree* y *remainder tree*, y posteriormente se cruzan los distintos bloques para detectar factores compartidos entre lotes diferentes. Este planteamiento permite controlar mejor el tamaño de los enteros intermedios y hacer viable el análisis de conjuntos mucho mayores de los que podría manejar una ejecución monolítica en memoria.

Por tanto, el enfoque clásico basado en *product tree* y *remainder tree* supuso un avance importante dentro del estado del arte, ya que permitió pasar de estrategias conceptualmente simples pero inasumibles a procedimientos realmente utilizables para auditar grandes colecciones de claves públicas RSA. Sin esta familia de métodos, gran parte de los estudios empíricos comentados en el apartado anterior no habría sido posible.

Sin embargo, que este enfoque haya sido el dominante durante años no significa que esté exento de limitaciones. De hecho, cuando se pretende seguir aumentando el tamaño de los conjuntos analizados, empiezan a aparecer dificultades prácticas relacionadas con el tiempo de ejecución, el consumo de memoria y la gestión de enteros de gran tamaño. Estas limitaciones serán precisamente el punto de partida del siguiente apartado.

3.5. Limitaciones del método clásico

Aunque el enfoque clásico basado en *product tree* y *remainder tree* supuso un gran avance respecto a la comparación ingenua de todos los pares, la propia literatura ha puesto de manifiesto que su aplica-

ción práctica a gran escala sigue presentando dificultades importantes. Estas limitaciones no invalidan el método, pero sí explican por qué resulta razonable seguir buscando alternativas más eficientes.

Una de las principales dificultades aparece en la parte alta de los árboles, donde los enteros intermedios alcanzan tamaños enormes. La tesis de Våge señala que el cuello de botella del algoritmo se encuentra precisamente en estas etapas, ya que el coste computacional crece a medida que se opera con números cada vez mayores Våge [2022]. Esto no solo afecta al tiempo de ejecución, sino también a la cantidad de memoria necesaria para mantener la estructura del cálculo.

Además, cuando el análisis se lleva a conjuntos realmente grandes, entran en juego problemas muy prácticos de ingeniería. En la ejecución descrita en la tesis, el experimento principal tuvo que dividirse en 13 lotes de alrededor de 12 millones de claves cada uno, y el proceso completo requirió del orden de 180 GB de memoria RAM, aproximadamente 1 TB de almacenamiento en disco y unas 88 horas de ejecución utilizando 30 núcleos Våge [2022]. Estas cifras dejan claro que, aunque el método clásico funciona, escalarlo no resulta trivial y exige recursos considerables.

La tesis también menciona otras complicaciones asociadas a este tipo de ejecuciones, como la necesidad de almacenar los datos de forma sistemática o los problemas derivados de trabajar con enteros muy grandes en bibliotecas de aritmética multiprecisión Våge [2022]. Todo ello refuerza la idea de que, cuando el objetivo es seguir ampliando el análisis sobre volúmenes masivos de certificados, el algoritmo utilizado pasa a ser un factor decisivo.

En la propia conclusión del trabajo, Våge señala que una mejora del algoritmo *batch GCD* permitiría investigaciones más grandes y más completas sobre el estado de la criptografía en la práctica Våge [2022]. Esta observación resulta especialmente importante, porque enlaza de forma directa con la propuesta de Pelofske y con la motivación de este TFM.

Por ello, las limitaciones del método clásico no deben entenderse como un fracaso del enfoque, sino como la consecuencia natural de intentar escalar el análisis a conjuntos cada vez mayores. Precisamente por eso, el siguiente paso dentro del estado del arte consiste en estudiar propuestas que mantengan la utilidad del *batch GCD*, pero reduzcan parte del coste práctico asociado al método tradicional.

3.6. Binary Tree Batch GCD como propuesta reciente

En este contexto aparece el trabajo de Pelofske, que propone una alternativa más reciente al enfoque clásico y la denomina *Binary Tree Batch GCD* Pelofske [2024]. El punto de partida del artículo es exactamente el mismo problema que hemos venido describiendo: cómo realizar un ataque *all-to-all GCD* sobre grandes conjuntos de módulos RSA para detectar factores compartidos debidos a baja entropía o a fallos de implementación.

Desde la perspectiva del estado del arte, lo más relevante de esta propuesta es que busca reducir parte del coste práctico asociado al método tradicional basado en *product tree* y *remainder tree*. Según el artículo, el nuevo enfoque evita construir explícitamente el *remainder tree* y mantiene una complejidad asintótica muy similar a la del método clásico Pelofske [2024].

Además, en los experimentos presentados por Pelofske, el algoritmo obtiene mejores tiempos de ejecución que el enfoque tradicional, con una mejora práctica media aproximada de seis veces Pelofske [2024]. Esto resulta especialmente interesante en un contexto como el nuestro, donde el problema no es solo detectar factores compartidos, sino hacerlo sobre conjuntos de datos cada vez mayores.

Por tanto, dentro de la literatura reciente, el *Binary Tree Batch GCD* puede interpretarse como una evolución natural del enfoque clásico. No cambia el problema que se quiere resolver, pero sí pro-

pone una forma distinta de abordarlo, con el objetivo de mejorar el rendimiento práctico y facilitar análisis de mayor escala sobre claves RSA potencialmente vulnerables.

3.7. Encaje y motivación del presente trabajo

A la vista de lo revisado en este capítulo, puede situarse con bastante claridad el punto exacto en el que se encuentra este Trabajo de Fin de Máster dentro de la literatura previa.

Por un lado, la tesis de Våge demostró que los *Certificate Transparency logs* constituyen una fuente valiosa para estudiar factores compartidos en claves RSA reales y que este tipo de análisis sigue ofreciendo resultados relevantes en la práctica Våge [2022]. Además, dejó abierta una idea especialmente importante para nuestro trabajo: si el algoritmo *batch GCD* pudiera mejorarse, sería posible llevar a cabo investigaciones más grandes y más completas sobre el estado real de la criptografía desplegada en Internet Våge [2022].

Por otro lado, el artículo de Pelofske propone precisamente una mejora algorítmica orientada a ese mismo problema, mostrando que el *Binary Tree Batch GCD* puede ofrecer una ventaja práctica significativa frente al método clásico basado en *remainder tree* Pelofske [2024]. Esto hace que ambas referencias encajen de forma especialmente natural entre sí: la tesis aporta el contexto aplicado, la fuente de datos y la motivación experimental, mientras que el artículo aporta la propuesta algorítmica más reciente.

Nuestro TFM se sitúa precisamente en la intersección entre ambos trabajos. Partiremos del problema y del contexto experimental planteados en la tesis, centrados en el análisis de claves RSA extraídas de *CT logs*, pero sustituiremos el núcleo algorítmico empleado en dicho trabajo por la propuesta de Pelofske. Con ello, buscaremos comprobar si esta alternativa constituye una mejora real en términos prácticos y si puede servir como base para futuras auditorías sobre conjuntos aún mayores de certificados.

De este modo, la aportación de este trabajo no consistirá en replantear el problema desde cero, sino en continuar una línea de investigación ya abierta, incorporando una herramienta más reciente y potencialmente más eficiente. Este posicionamiento resulta, a nuestro juicio, especialmente adecuado para un Trabajo de Fin de Máster, ya que combina revisión crítica de trabajos previos, implementación experimental y análisis aplicado sobre un problema real de ciberseguridad.

Una vez establecido este marco, en el capítulo siguiente nos centraremos ya en la parte metodológica del trabajo. En particular, describiremos con más detalle el fundamento del *batch GCD*, el algoritmo *Binary Tree Batch GCD* y las decisiones de implementación adoptadas para llevar a cabo nuestros experimentos.

Capítulo 4

Metodología y algoritmo propuesto

Una vez revisados los antecedentes principales del problema y situado este TFM dentro de la literatura previa, en este capítulo pasaremos a describir la metodología seguida en nuestro trabajo.

Como se ha visto en el capítulo anterior, partimos de una línea de investigación ya existente centrada en la detección de factores compartidos en claves RSA públicas obtenidas a partir de *Certificate Transparency logs*. En particular, tomaremos como referencia el planteamiento experimental de la tesis de Våge, pero sustituiremos el enfoque clásico basado en *product tree* y *remainder tree* por la propuesta más reciente de Pelofske, el algoritmo *Binary Tree Batch GCD* [Pelofske \[2024\]](#); [Våge \[2022\]](#).

Nuestro objetivo será estudiar si esta alternativa resulta adecuada para el problema que nos ocupa y si puede constituir una mejora práctica frente al método tradicional. Para ello, no nos limitaremos a revisar el algoritmo desde un punto de vista teórico, sino que lo implementaremos y lo aplicaremos en dos contextos distintos: primero sobre datos sintéticos generados de forma controlada y, después, sobre datos reales obtenidos a partir de *CT logs*.

La metodología del trabajo se apoyará, por tanto, en tres pilares principales. En primer lugar, el fundamento general de los métodos *batch GCD*, ya que constituyen la base matemática y algorítmica de este tipo de ataques. En segundo lugar, la aplicación concreta del algoritmo *Binary Tree Batch GCD* como núcleo de nuestro análisis. Y, en tercer lugar, el desarrollo de una implementación práctica que permita evaluar su comportamiento en escenarios sintéticos y reales.

A continuación, describiremos primero el fundamento general del *batch GCD*, después el funcionamiento del algoritmo seleccionado y, por último, la implementación desarrollada para llevar a cabo nuestros experimentos.

4.1. Fundamento del *batch GCD*

Como ya se ha visto en los capítulos anteriores, la detección de factores compartidos entre claves públicas RSA se basa en una idea sencilla: si dos módulos comparten un factor primo, dicho factor puede recuperarse calculando su máximo común divisor. El problema aparece cuando no queremos estudiar solo un par de módulos, sino un conjunto muy grande de ellos. En ese escenario, ya no basta con saber que el cálculo individual de un *gcd* es eficiente, sino que debemos enfrentarnos al hecho de que no conocemos de antemano qué pares de claves podrían compartir factores.

Si el conjunto contiene M módulos RSA, una estrategia de fuerza bruta exigiría realizar

$$\frac{M(M-1)}{2}$$

comparaciones distintas, ya que habría que estudiar todos los pares posibles. Aunque cada cálculo

individual de *gcd* sea barato, el número total de operaciones crece de forma cuadrática con el tamaño del conjunto, lo que convierte este enfoque en una opción poco realista cuando trabajamos con miles, millones o incluso cientos de millones de claves. El artículo de Pelofske insiste precisamente en esta idea al presentar el problema como un ataque *all-to-all GCD* Pelofske [2024].

A partir de esta limitación surge la necesidad de diseñar métodos que permitan detectar factores compartidos sin tener que comparar cada módulo con todos los demás de forma aislada. Esa es la idea que da lugar a los algoritmos *batch GCD*. En términos generales, estos métodos no cambian el objetivo final del ataque, que sigue siendo identificar divisores comunes no triviales dentro de un conjunto de módulos RSA, pero sí modifican la forma de organizar el cálculo para aprovechar la estructura global del conjunto y reducir de manera importante el coste práctico Pelofske [2024]; Våge [2022].

Dentro de esta familia de enfoques, el método clásico descrito en la tesis de Våge parte de la construcción de un *product tree* y un *remainder tree*. La idea básica es agrupar los módulos del conjunto de manera jerárquica, multiplicándolos para formar productos intermedios cada vez mayores. Después, mediante el árbol de residuos, se comprueba en las hojas si un determinado módulo comparte algún factor con el producto del resto. De esta forma, el análisis deja de estar planteado como una colección de comparaciones independientes y pasa a organizarse alrededor de operaciones sobre árboles, lo que permite escalar mucho mejor que la enumeración exhaustiva de todos los pares Pelofske [2024]; Våge [2022].

La tesis explica además que, para trabajar con colecciones muy grandes de claves, este planteamiento puede extenderse al denominado *batch GCD algorithm*. En este caso, el conjunto completo de claves se divide en varios lotes o *batches*, y sobre cada uno de ellos se construyen sus correspondientes árboles de productos y residuos. Este paso permite controlar mejor el tamaño de los enteros en la parte alta de los árboles y, por tanto, reducir el cuello de botella asociado al manejo de productos gigantescos. Sin embargo, esta división introduce también una consecuencia importante: para detectar factores compartidos entre módulos pertenecientes a lotes distintos, cada producto grande de un lote debe comprobarse frente a los árboles de residuos de los demás, de modo que el algoritmo debe repetirse múltiples veces entre lotes Våge [2022].

Por tanto, desde un punto de vista metodológico, el fundamento del *batch GCD* puede resumirse en la siguiente idea: en lugar de preguntar por separado si cada par de módulos comparte un factor, se reorganiza el problema para explotar productos agregados que contienen información sobre muchos módulos a la vez. Esto permite detectar divisores comunes sin recorrer explícitamente todas las comparaciones posibles. En otras palabras, el *batch GCD* no elimina la lógica del ataque por máximo común divisor, pero sí sustituye una búsqueda par a par por una estrategia global mucho más escalable.

Esta perspectiva también aparece de forma clara en el artículo de Pelofske. Allí se explica que el objetivo de fondo consiste en cubrir, de manera eficiente, el equivalente a todas las comparaciones necesarias en un problema *all-to-all GCD*. Según el artículo, una propiedad importante del máximo común divisor es que, si dividimos el conjunto de enteros en dos mitades y calculamos el *gcd* entre los productos de ambas, obtenemos de una sola vez información sobre muchos divisores comunes que aparecerían en comparaciones individuales. Aunque una sola partición no cubre todas las combinaciones posibles, la idea puede aplicarse de forma recursiva mediante una estructura arbórea, lo que permite recuperar la información necesaria sobre todos los factores compartidos presentes en el conjunto Pelofske [2024].

Visto así, el *batch GCD* no debe entenderse únicamente como una optimización práctica, sino como el núcleo algorítmico que hace viable este tipo de auditorías criptográficas a gran escala. Sin una reorganización de este tipo, analizar colecciones masivas de claves RSA reales, como las procedentes de *Certificate Transparency logs*, sería computacionalmente muy costoso. Por ello, tanto el enfoque

clásico basado en *product tree* y *remainder tree* como la propuesta más reciente de Pelofske pueden interpretarse como distintas formas de materializar una misma idea general: transformar un ataque basado en comparaciones par a par en un procedimiento global y escalable.

Una vez establecido este fundamento general, en el siguiente apartado describiremos ya con más detalle el algoritmo *Binary Tree Batch GCD*, que será el núcleo metodológico de nuestro trabajo.

4.2. Algoritmo *Binary Tree Batch GCD*

Una vez introducido el fundamento general de los métodos *batch GCD*, en este apartado describiremos con más detalle el algoritmo *Binary Tree Batch GCD*, que constituye el núcleo metodológico de nuestro trabajo. Aquí nos centraremos en su funcionamiento y en la lógica que seguiremos posteriormente en nuestra implementación.

El artículo de Pelofske define el algoritmo en tres pasos principales Pelofske [2024]. En primer lugar, se construye un árbol binario de productos a partir del conjunto de módulos RSA de entrada. En segundo lugar, se toma el producto de todos los valores de *gcd* obtenidos durante la construcción del árbol y se agrupan en un único entero, que el artículo denota por B . En tercer lugar, se enumera el conjunto original de módulos y se calcula el *gcd* entre cada uno de ellos y B , de modo que los resultados no triviales permiten recuperar los factores compartidos Pelofske [2024].

Si denotamos por

$$N = \{N_1, N_2, \dots, N_M\}$$

el conjunto de módulos RSA que queremos analizar, la idea básica del algoritmo consiste en no comparar cada par de módulos de manera aislada, sino organizar el cálculo de forma jerárquica. Para ello, en el nivel más bajo del árbol se agrupan los módulos por parejas. Para cada pareja se realizan dos operaciones: por un lado, se calcula su máximo común divisor y, por otro, se calcula su producto. Los productos obtenidos pasan al siguiente nivel del árbol, mientras que los *gcd* calculados se conservan como parte de la información que luego se agregará en B Pelofske [2024].

En los niveles superiores se repite la misma idea, pero ya no con módulos individuales, sino con los productos generados en el nivel anterior. Si en un cierto nivel tenemos dos nodos con valores A y C , se calcula

$$\gcd(A, C)$$

y, salvo en la raíz, también se calcula el producto

$$A \cdot C$$

para construir el nodo padre. Este procedimiento se aplica de forma recursiva hasta alcanzar la parte superior del árbol Pelofske [2024].

La intuición detrás de este diseño es importante. Tal y como explica Pelofske, si dividimos el conjunto de enteros en dos mitades y calculamos el *gcd* entre el producto de una mitad y el producto de la otra, obtenemos de una sola vez información equivalente a un gran número de comparaciones individuales entre elementos de ambas mitades Pelofske [2024]. Una sola partición no cubre todas las combinaciones posibles, pero al aplicar esta idea recursivamente sobre un árbol binario sí se consigue cubrir, en conjunto, toda la información necesaria para un problema *all-to-all GCD*.

Una vez construido el árbol, el algoritmo dispone de todos los valores de *gcd* generados en sus nodos

internos. Si el árbol tiene M hojas, el número de nodos internos es $M - 1$, y por tanto se obtiene exactamente ese número de resultados intermedios de *gcd* Pelofske [2024]. El siguiente paso consiste en tomar todos esos resultados y multiplicarlos entre sí para formar un único entero, que denotaremos por B . Formalmente, si llamamos $g_1, g_2, \dots, g_{M-1}$ a los valores de *gcd* obtenidos durante la construcción del árbol, entonces se define

$$B = \prod_{j=1}^{M-1} g_j$$

Si $B = 1$, entonces no se ha encontrado ningún divisor común no trivial en el conjunto de módulos analizado. En cambio, si $B > 1$, ese entero contiene la información agregada sobre los factores compartidos presentes en el conjunto Pelofske [2024].

El tercer y último paso consiste en recorrer de nuevo el conjunto original de módulos y calcular, para cada N_i , el valor

$$\gcd(N_i, B)$$

Cualquier resultado no trivial obtenido en esta enumeración indica que el módulo N_i comparte algún factor con otro módulo del conjunto. De este modo, el algoritmo transforma toda la información agregada en B en factores concretos asociados a módulos individuales Pelofske [2024].

Según el artículo, el número exacto de operaciones de *gcd* realizadas por este procedimiento es $M - 1$ durante la construcción del árbol, más M en la fase final de enumeración, es decir, un total de

$$2M - 1$$

operaciones de *gcd* Pelofske [2024]. Esto contrasta fuertemente con el número cuadrático de comparaciones que exigiría una estrategia ingenua basada en revisar todos los pares posibles.

Una ventaja importante de este enfoque es que no necesita construir explícitamente un *remainder tree*, como ocurre en el método clásico. En su lugar, la información relevante se va acumulando a través de los *gcd* calculados en los nodos del árbol y del producto agregado B . Según Pelofske, esta es precisamente la característica que permite reducir parte del coste práctico respecto al enfoque tradicional, manteniendo al mismo tiempo una complejidad asintótica del mismo orden, dominada por la construcción del árbol de productos Pelofske [2024].

No obstante, el propio artículo también señala una limitación importante. El comportamiento práctico del algoritmo depende de cuántos factores compartidos existan realmente en el conjunto y de cómo estén distribuidos Pelofske [2024]. En particular, pueden aparecer casos más costosos cuando un mismo módulo contiene varios factores que también aparecen en otras claves del conjunto. Aunque este tipo de situaciones no invalida el algoritmo, sí conviene tenerlo en cuenta desde el punto de vista de la implementación.

Desde una perspectiva metodológica, el interés del *Binary Tree Batch GCD* en nuestro trabajo radica en que organiza el problema de forma especialmente adecuada para su implementación eficiente. La estructura binaria facilita la separación del proceso en fases bien definidas: construcción del árbol, acumulación de divisores comunes y enumeración final sobre el conjunto original. Esta organización resulta útil tanto para gestionar la memoria como para plantear posibles estrategias de paralelización, aspectos que serán importantes en la implementación desarrollada en este TFM.

4.3. Implementación desarrollada

La implementación principal utilizada en este trabajo se ha desarrollado en C++17 empleando la biblioteca GMP para la aritmética multiprecisión. La elección de C++ responde a la necesidad

de trabajar con enteros muy grandes de manera eficiente y de disponer de un mayor control sobre el uso de memoria y el rendimiento general de la ejecución. El código está preparado para aprovechar OpenMP cuando el entorno lo permite, aunque la comparativa local presentada en el capítulo siguiente se ejecutó con una versión secuencial enlazada únicamente contra GMP, con el fin de evitar dependencias externas no disponibles en el sistema.

Siguiendo la lógica del algoritmo descrito en el apartado anterior, la implementación se ha organizado en tres fases claramente diferenciadas. La primera corresponde a la construcción del árbol binario de productos con cálculo de *gcd* en línea. En esta etapa, los módulos RSA se agrupan por parejas y, en cada nodo, se calcula tanto el producto que se propagará al nivel superior como el *gcd* entre ambos hijos. Los valores de *gcd* no triviales se almacenan para ser utilizados posteriormente en la fase de agregación.

Una decisión importante de implementación ha sido liberar los hijos de cada nodo tan pronto como dejan de ser necesarios. De este modo evitamos mantener en memoria más información de la estrictamente necesaria y reducimos el pico de uso de RAM durante la construcción del árbol. Esta decisión es especialmente importante en un problema como este, donde el tamaño de los enteros intermedios crece rápidamente conforme se asciende por los niveles de la estructura.

La segunda fase consiste en la agregación de todos los divisores comunes no triviales en una única variable *B*. En la versión actual de la implementación, esta agregación se realiza multiplicando secuencialmente los valores almacenados en la fase anterior. Aunque esta parte todavía podría optimizarse más en el futuro, resulta suficiente para validar el comportamiento general del algoritmo y mantener una estructura clara del proceso.

La tercera fase corresponde a la enumeración final sobre el conjunto original de módulos. Para cada N_i , se calcula $\gcd(N_i, B)$ y se comprueba si el resultado es no trivial. Esta fase es especialmente adecuada para una posible paralelización, ya que cada comprobación puede realizarse de forma independiente sobre módulos distintos. Por esta razón, la implementación incluye soporte opcional para OpenMP, aunque el diseño del algoritmo no depende de dicha paralelización.

Para la comparación experimental se utilizaron también las implementaciones Python originales del repositorio de Pelofske. No obstante, dicho repositorio no pudo ejecutarse directamente sin pequeñas adaptaciones de compatibilidad. En particular, fue necesario restaurar el alias `np.product`, eliminado en NumPy 2.0, y resolver las rutas relativas utilizadas por la función de generación de claves débiles. Estas adaptaciones se implementaron mediante *wrappers* externos que importan el código original sin modificar su lógica algorítmica.

Los datos sintéticos se generaron siguiendo la función `generate_weak_keys` del repositorio original. Para cada configuración se creó un archivo de módulos RSA en formato hexadecimal, uno por línea. Ese mismo archivo se utilizó como entrada para los tres algoritmos comparados: el *Remainder Tree Batch GCD* en Python, el *Binary Tree Batch GCD* en Python y nuestra implementación C++/GMP. Esta decisión garantiza que las diferencias observadas en los resultados se deban al algoritmo y a la implementación, no a variaciones en los datos de entrada.

Además, se ha trabajado con un flujo de preparación de datos reales procedentes de *Certificate Transparency*. Inicialmente se utilizó una muestra local ya extraída y normalizada, lo que permitió validar que el binario era capaz de leer módulos RSA reales, eliminar duplicados y ejecutar el algoritmo completo. Sin embargo, el objetivo aplicado del trabajo requiere ir más allá de esa muestra y preparar un proceso que pueda alimentarse directamente de colecciones mucho mayores de certificados.

Para ello se ha utilizado como fuente de datos el archivo público *ct-archive*, que recopila volcados de distintos *Certificate Transparency logs* en forma de archivos comprimidos. En lugar de descargar y

conservar de manera permanente todos los certificados, el flujo diseñado trabaja de forma incremental: se descarga un archivo comprimido, se inspecciona su contenido, se extraen únicamente las entradas situadas en la carpeta `issuer/` o `issuers/`, y se obtiene de cada certificado X.509 su módulo RSA y su emisor. Esta decisión reduce el espacio necesario en disco y permite procesar los logs por partes, manteniendo únicamente los resultados intermedios necesarios para continuar el análisis.

El campo de módulo se extrae mediante OpenSSL y se almacena en formato hexadecimal. Además del módulo, se conserva también el emisor del certificado, de modo que la salida intermedia contiene pares de la forma `modulo||issuer`. Esta información adicional no es necesaria para ejecutar el algoritmo *batch GCD*, pero sí resulta útil para interpretar posteriormente cualquier factor compartido encontrado, ya que permitiría relacionar los módulos vulnerables con las autoridades certificadoras o intermediarias que aparecen en los certificados analizados.

El proceso incluye una fase de normalización y deduplicación. Muchos certificados pueden contener el mismo módulo RSA, bien por renovaciones, por certificados equivalentes o por presencia repetida en distintos logs. Ejecutar el algoritmo sobre todas esas repeticiones no aporta información criptográfica nueva y aumenta artificialmente el tamaño de entrada. Por ello, antes de lanzar el ataque se genera un archivo final con un único módulo hexadecimal por línea. Este archivo es el que alimenta a la implementación C++.

Durante la extracción se mantiene también un registro del estado de cada archivo comprimido. Los archivos ya procesados, los que fallan y los que aparentemente no contienen entradas `issuer/` se registran por separado. Esta distinción es importante porque, en la práctica, un archivo descargado de forma incompleta puede parecer inválido o no contener las rutas esperadas aunque el problema real sea una descarga parcial. Por este motivo, los casos marcados como ausencia de `issuer/` se revisan de forma conservadora antes de descartarlos definitivamente. Si el archivo local no es un ZIP válido, se conserva como evidencia, se elimina su marca de procesado y se vuelve a descargar.

La descarga se realiza mediante HTTP con reanudación, en lugar de basarse directamente en los enlaces Torrent disponibles en la misma fuente. La razón es principalmente operativa: el flujo del TFM necesita controlar cada ZIP de manera independiente, procesarlo, registrar su estado y liberar espacio cuando deja de ser necesario. El uso de Torrent podría ser útil para replicar colecciones completas o como alternativa para recuperar archivos problemáticos, pero resulta menos directo para un procesamiento incremental ZIP a ZIP como el empleado aquí.

Este paso es importante porque conecta la parte algorítmica con el objetivo aplicado del TFM. La implementación no se plantea únicamente como una reproducción de un experimento sintético, sino como la base para ejecutar el ataque *all-to-all GCD* sobre certificados reales. En el entorno local se utiliza una muestra ya normalizada para validar el procedimiento completo, mientras que la extracción incremental de módulos desde *CT logs* prepara la entrada que se ejecutará posteriormente en Altamira sobre un conjunto mucho mayor.

CT logs $\longrightarrow$ certificados X.509 $\longrightarrow$ `modulo||issuer` $\longrightarrow$ módulos únicos $\longrightarrow$ `batch_gcd_real`

Desde el punto de vista de la documentación del trabajo, no consideramos conveniente incluir en el cuerpo principal del TFM las celdas completas del notebook ni los listados íntegros del código fuente, ya que eso dificultaría la lectura del documento y rompería el hilo expositivo. En su lugar, en este capítulo nos limitamos a describir la lógica general de la implementación y a comentar las decisiones técnicas más relevantes. Los notebooks, los binarios y los resultados generados se mantienen como material complementario del trabajo.

Por tanto, la implementación desarrollada en este TFM debe entenderse como una traducción práctica del algoritmo *Binary Tree Batch GCD* a un entorno eficiente de ejecución, validada frente a las imple-

mentaciones Python de referencia y adaptada tanto a experimentos controlados con datos sintéticos como a módulos RSA reales extraídos de *CT logs*. Sobre esta implementación se apoyan los resultados que presentaremos en el capítulo siguiente y la campaña de ejecución preparada para Altamira.

Capítulo 5

Resultados y discusión

En este capítulo presentamos los resultados obtenidos a partir de la metodología descrita anteriormente. La evaluación se organiza en dos partes. En primer lugar, se estudia el comportamiento de los algoritmos sobre datos sintéticos generados de forma controlada, siguiendo la estructura experimental del artículo de Pelofske. En segundo lugar, se aplica la implementación desarrollada a módulos RSA reales extraídos de *Certificate Transparency logs*. Esta segunda parte incluye una validación local sobre una muestra ya normalizada y la preparación de una campaña de mayor escala basada en módulos extraídos incrementalmente de *CT logs*.

El objetivo principal de la primera parte no es únicamente comprobar que la implementación desarrollada funciona correctamente, sino también comparar su comportamiento con las implementaciones Python del repositorio original. De este modo, la evaluación permite estudiar tres aspectos complementarios: la diferencia entre el enfoque clásico basado en *remainder tree* y el algoritmo *Binary Tree Batch GCD*, el efecto de trasladar este último a C++ con GMP, y la influencia del número de claves débiles introducidas en el conjunto.

5.1. Configuración de la comparativa sintética

La comparativa sintética se diseñó tomando como referencia la Figura 2 del artículo de Pelofske [Pelofske \[2024\]](#). En dicho experimento se analizan dos tamaños de módulo RSA, 1024 y 2048 bits, y tres valores distintos para el número de claves débiles: 2, 100 y 1000. En nuestro caso se mantuvo esta misma estructura experimental, pero utilizando una parrilla reducida de tamaños de entrada para que la ejecución fuese viable en un entorno local.

En concreto, se utilizaron módulos RSA de 1024 y 2048 bits, generados como producto de primos de 512 y 1024 bits respectivamente. Para cada tamaño de módulo se probaron los valores $\text{WEAK} = 2$, $\text{WEAK} = 100$ y $\text{WEAK} = 1000$, y para cada una de estas configuraciones se evaluaron conjuntos de $N = 2000$, $N = 5000$ y $N = 10000$ módulos. Estos valores de N son menores que los empleados en el artículo original, donde se llega hasta 75000 módulos para claves RSA-2048 y hasta 120000 módulos para claves RSA-1024. Esta reducción responde al coste computacional de ejecutar las implementaciones Python originales en un portátil, especialmente en el caso del método basado en *remainder tree*.

Los tres algoritmos comparados fueron los siguientes:

- *Remainder Tree Batch GCD*, utilizando la implementación Python original del repositorio de Pelofske.
- *Binary Tree Batch GCD*, utilizando también la implementación Python original del mismo repositorio.

- *Binary Tree Batch GCD* en C++17 con GMP, correspondiente a la implementación desarrollada en este trabajo.

Para garantizar que la comparación fuese homogénea, cada combinación de tamaño de módulo, valor de **WEAK** y valor de N generó un único archivo de módulos en hexadecimal. Los tres algoritmos se ejecutaron después sobre ese mismo archivo de entrada. De este modo, las diferencias observadas en tiempo de ejecución y consumo de memoria no se deben a variaciones en los datos, sino a la implementación y al algoritmo utilizado.

El repositorio original de Pelofske no pudo utilizarse directamente sin adaptaciones. En particular, fue necesario introducir una capa de compatibilidad para versiones actuales de NumPy, ya que el código original utiliza `np.product`, alias eliminado en NumPy 2.0. También fue necesario resolver las rutas relativas empleadas por la función de generación de claves débiles, que espera encontrar los primos en un directorio `primes/` relativo a la raíz del repositorio. Estas modificaciones no alteran la lógica algorítmica de las implementaciones Python, sino que permiten ejecutarlas en un entorno actual.

5.2. Validación funcional

Antes de analizar los tiempos de ejecución, se comprobó que los tres algoritmos identificaban los mismos módulos vulnerables en cada configuración experimental. Esta validación es importante porque la implementación C++ no solo debe ser más rápida, sino también producir resultados compatibles con las implementaciones Python de referencia.

Los resultados fueron consistentes en todas las combinaciones evaluadas: para cada conjunto sintético, los tres algoritmos detectaron exactamente el mismo número de módulos con factores compartidos. Por ejemplo, para **WEAK** = 2 se detectaron 4 módulos vulnerables; para **WEAK** = 100, los valores estuvieron alrededor de 200; y para **WEAK** = 1000, los valores oscilaron entre 1747 y 1970 según el tamaño total del conjunto.

Conviene aclarar que el número de módulos vulnerables detectados no tiene por qué coincidir exactamente con el parámetro **WEAK**. La función de generación utilizada por el repositorio original introduce nuevos módulos que comparten un factor con módulos ya existentes. Por tanto, al detectar vulnerabilidades aparecen tanto los módulos añadidos como los módulos originales con los que comparten factor. Además, cuando un mismo módulo original contiene dos factores que han sido reutilizados en módulos débiles distintos, el número total de módulos vulnerables puede ser menor que $2 \cdot \text{WEAK}$. Lo relevante para nuestra validación es que las tres implementaciones coincidieron exactamente en todos los casos.

5.3. Comparación de tiempos de ejecución

La Figura 1 muestra los tiempos de ejecución de los tres algoritmos. La figura se organiza de forma análoga al experimento de Pelofske: las filas distinguen el tamaño del módulo RSA y las columnas representan los distintos valores de **WEAK**. La escala del eje vertical es logarítmica, ya que las diferencias entre la implementación C++ y las implementaciones Python son demasiado grandes para apreciarse correctamente en una escala lineal.

Los resultados muestran una tendencia clara. En primer lugar, la implementación Python del *Binary Tree Batch GCD* mejora de forma consistente al método clásico basado en *Remainder Tree Batch GCD*. En promedio, el algoritmo de árbol binario fue aproximadamente 6,1 veces más rápido que el método clásico, con aceleraciones entre 3,6 y 7,9 según la configuración.

En segundo lugar, la implementación C++ con GMP reduce de forma muy significativa el tiempo de ejecución respecto a las dos versiones Python. Frente al *Remainder Tree Batch GCD*, la aceleración

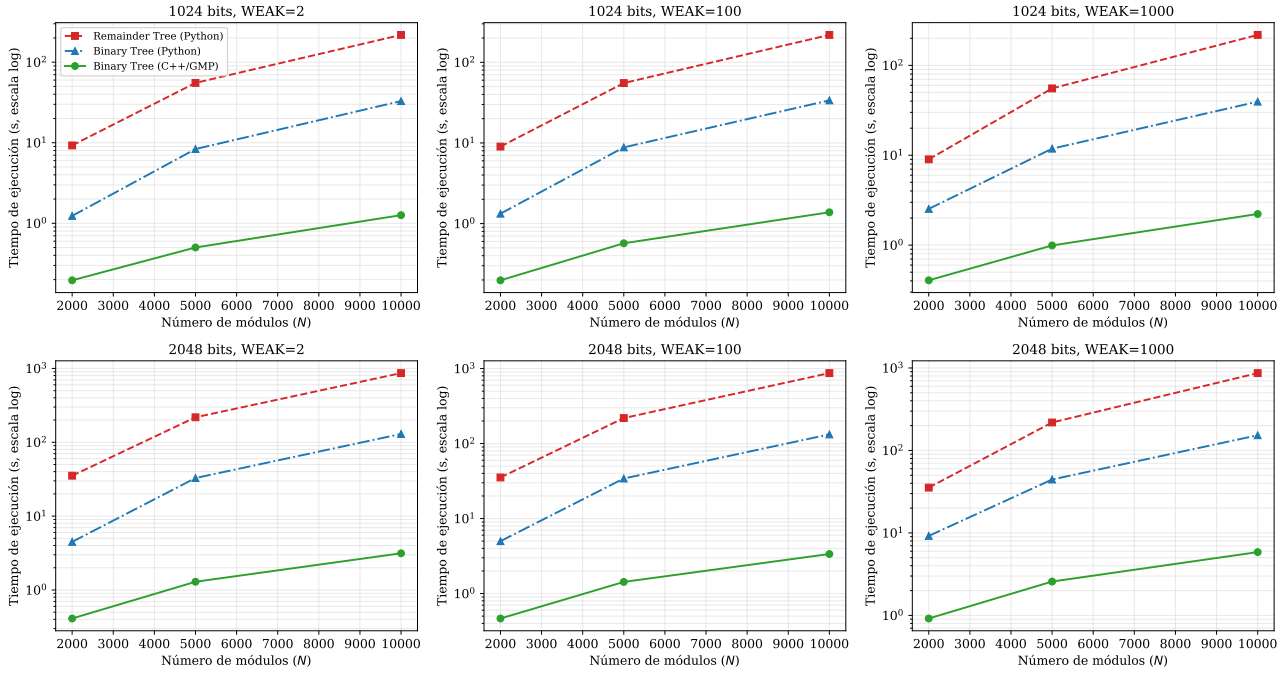


Ilustración 1: Comparación del tiempo de ejecución de los tres algoritmos evaluados sobre datos sintéticos.

media fue de aproximadamente 116,5 veces, alcanzando un máximo de 275,3 veces. Frente al *Binary Tree Batch GCD* en Python, la implementación C++ fue en promedio 18,7 veces más rápida, con un máximo de 41,3 veces.

La Tabla 1 recoge algunos casos representativos de la comparativa. El caso más exigente dentro de nuestra parrilla experimental corresponde a módulos RSA de 2048 bits, $N = 10000$ y $WEAK = 1000$. En esa configuración, el método clásico tardó 866,819 segundos, la versión Python del algoritmo de Pelofske tardó 152,803 segundos y la implementación C++/GMP completó la ejecución en 5,851 segundos.

Bits	WEAK	N	Remainder Python	Binary Python	Binary C++/GMP
1024	100	10000	218,579 s	33,721 s	1,381 s
2048	100	10000	870,017 s	132,484 s	3,368 s
2048	1000	10000	866,819 s	152,803 s	5,851 s

Cuadro 1: Tiempos representativos de la comparativa sintética.

Estos resultados son coherentes con la motivación del artículo de Pelofske. El algoritmo *Binary Tree Batch GCD* reduce el coste práctico frente al método clásico al evitar la construcción explícita de un *remainder tree*. Nuestra implementación confirma además que, al trasladar esta lógica a C++ y utilizar una biblioteca optimizada para aritmética multiprecisión como GMP, la mejora práctica es mucho mayor.

5.4. Comparación de consumo de memoria

Además del tiempo de ejecución, también se midió el pico de memoria RAM consumida por cada algoritmo. La Figura 2 muestra los resultados obtenidos.

La tendencia observada es también favorable a la implementación C++/GMP. El mayor pico de memoria registrado para el método clásico en Python fue de 128,70 MB, mientras que la versión Python del algoritmo de Pelofske alcanzó 94,39 MB. En cambio, la implementación C++/GMP tuvo

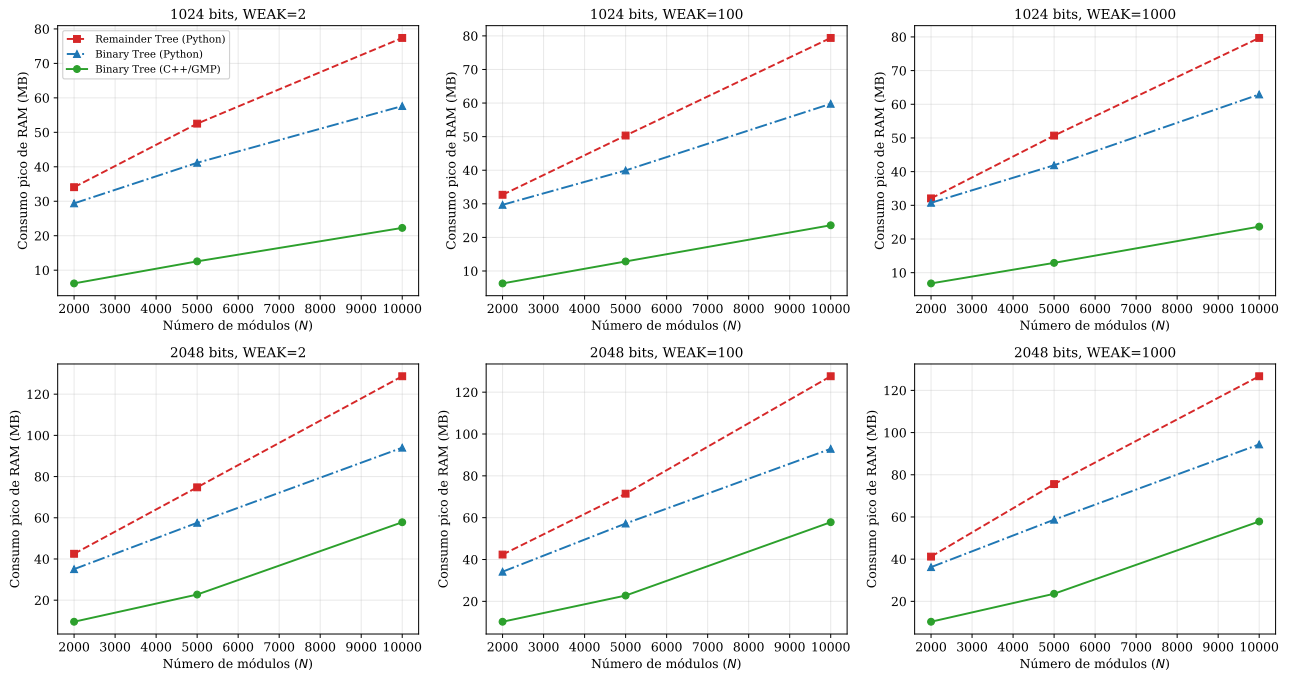


Ilustración 2: Comparación del consumo pico de memoria de los tres algoritmos evaluados.

un máximo de 57,86 MB en el conjunto de experimentos.

Esta diferencia no debe interpretarse únicamente como una consecuencia del lenguaje utilizado. También está relacionada con la forma en que la implementación gestiona los enteros intermedios durante la construcción del árbol. En particular, en la versión C++ se liberan los hijos de cada nodo cuando dejan de ser necesarios, reduciendo así la cantidad de datos mantenidos simultáneamente en memoria. Aunque el tamaño de los enteros crece inevitablemente al ascender por el árbol, esta gestión permite contener el pico de RAM.

5.5. Efecto del número de claves débiles

El parámetro **WEAK** permite observar cómo afecta la cantidad de factores compartidos al comportamiento de los algoritmos. Los resultados muestran que el método clásico basado en *remainder tree* apenas cambia al variar este parámetro. Por ejemplo, con módulos RSA de 2048 bits y $N = 10000$, los tiempos fueron 864,321 segundos para **WEAK** = 2, 870,017 segundos para **WEAK** = 100 y 866,819 segundos para **WEAK** = 1000.

En cambio, el efecto de **WEAK** sí es más visible en el algoritmo de árbol binario. En la misma configuración de 2048 bits y $N = 10000$, la versión Python pasó de 129,501 segundos con **WEAK** = 2 a 152,803 segundos con **WEAK** = 1000. La implementación C++/GMP pasó de 3,139 segundos a 5,851 segundos.

Este comportamiento encaja con la interpretación del propio artículo de Pelofske. El algoritmo *Binary Tree Batch GCD* resulta especialmente ventajoso cuando el número de factores compartidos es pequeño en comparación con el tamaño total del conjunto. A medida que aumenta el número de módulos débiles, la ventaja se reduce parcialmente, aunque el algoritmo sigue siendo claramente más eficiente que el enfoque clásico en todas las configuraciones evaluadas.

5.6. Aplicación a datos reales

Una vez validado el comportamiento sobre datos sintéticos y comparado con las implementaciones de referencia, el siguiente paso consiste en aplicar el algoritmo a certificados reales. Esta parte es la que conecta directamente con el objetivo aplicado del TFM: utilizar el nuevo algoritmo para buscar factores RSA compartidos en certificados extraídos de *CT logs*.

La primera validación se realizó en el entorno local con una muestra ya extraída y normalizada en un archivo de texto comprimido. Tras descomprimirlo, el archivo contiene registros procedentes de certificados X.509, incluyendo el emisor y el módulo cuando la clave pública es RSA. Dentro de esta muestra aparecen 112230 registros de certificado: 87462 contienen un módulo RSA y 24768 corresponden a claves para las que no se obtiene módulo RSA. Al eliminar duplicados, el conjunto utilizado por el algoritmo quedó reducido a 601 módulos RSA únicos. De ellos, 318 corresponden a módulos de 2048 bits, 94 a módulos de 3072 bits y 189 a módulos de 4096 bits.

Elemento de la muestra local	Valor
Registros de certificado analizados	112230
Registros con módulo RSA	87462
Registros sin módulo RSA	24768
Módulos RSA únicos utilizados	601
Módulos RSA-2048 únicos	318
Módulos RSA-3072 únicos	94
Módulos RSA-4096 únicos	189

Cuadro 2: Resumen de la muestra real utilizada en la validación local.

La ejecución del binario `batch_gcd_real` sobre esta muestra confirmó que el programa podía procesar correctamente módulos RSA reales en el mismo formato utilizado para los experimentos sintéticos. La ejecución se realizó en modo secuencial, sin OpenMP, y cargó 601 módulos RSA. El árbol binario construido tuvo 10 niveles, no se encontraron *gcd* no triviales durante la construcción y la fase final no detectó claves vulnerables. El tiempo total del algoritmo fue de 107,17 milisegundos.

Este resultado no debe interpretarse como una conclusión general sobre la seguridad de los *CT logs*. La muestra local es pequeña en comparación con los estudios previos y también con el conjunto completo disponible para la siguiente fase del trabajo. Su utilidad principal es validar el flujo completo: extracción de certificados, filtrado de claves RSA, normalización de módulos, eliminación de duplicados y ejecución del algoritmo sobre datos reales.

`real_moduli.txt` $\rightarrow$ `batch_gcd_real` $\rightarrow$ factores compartidos detectados

El conjunto real analizado contiene 87462 registros con módulo RSA antes de eliminar duplicados. Un análisis ingenuo de todos los pares posibles sobre esos módulos requeriría

$$\frac{87462 \cdot 87461}{2} = 3824756991$$

comparaciones de máximo común divisor, lo que justifica la necesidad de utilizar un enfoque *batch GCD*. En la práctica, además, se eliminan duplicados antes de ejecutar el algoritmo, ya que repetir varias veces el mismo módulo no aporta información nueva sobre factores compartidos y solo aumenta artificialmente el coste del análisis.

5.7. Preparación de la campaña sobre *CT logs*

La muestra anterior permitió validar el flujo de extremo a extremo, pero no representa todavía el objetivo aplicado completo del trabajo. Para aproximarnos a una ejecución más realista se preparó

una campaña de extracción de módulos a partir de *ct-archive*, una colección pública de volcados de *Certificate Transparency logs*. Esta fuente proporciona los datos organizados por log y por archivos comprimidos, lo que permite trabajar por partes sin necesidad de almacenar simultáneamente toda la colección.

En esta fase se seleccionaron logs de DigiCert hasta *wyvern2025h1*, incluido. Para cada log, el procedimiento descarga los archivos ZIP correspondientes y extrae únicamente los certificados situados bajo las rutas *issuer/* o *issuers/*. A partir de cada certificado se obtiene el módulo de la clave pública RSA y el emisor. La salida intermedia mantiene los pares *modulo||issuer*, mientras que la entrada final para el algoritmo se construye eliminando duplicados y conservando un único módulo hexadecimal por línea.

El hecho de mantener el emisor junto al módulo no modifica el ataque *batch GCD*, pero resulta importante desde el punto de vista del análisis posterior. Si se detectan factores compartidos, disponer del emisor permite estudiar si los módulos afectados se concentran en una autoridad certificadora, en una cadena concreta o en certificados relacionados. Por tanto, la extracción no se limita a preparar una lista de enteros, sino que conserva información contextual suficiente para interpretar los resultados.

La extracción se diseñó de forma incremental y tolerante a fallos. Cada archivo comprimido se registra como procesado, fallido o pendiente. Además, los casos que aparentemente no contienen carpeta *issuer/* se revisan con especial cuidado, ya que una descarga parcial puede provocar que el archivo local no sea un ZIP válido y lleve a una clasificación incorrecta. En esos casos, el archivo parcial se conserva como evidencia y se fuerza una nueva descarga antes de decidir si realmente carece de información útil.

Durante esta campaña se observó precisamente este tipo de situación: algunos archivos marcados inicialmente como carentes de *issuer/* resultaron ser descargas incompletas. Al revisarlos, se comprobó que no eran ZIPs válidos y se reprocesaron de forma conservadora. Esta comprobación es relevante porque evita descartar partes del conjunto de datos por un problema de descarga, y muestra que la fase de preparación de datos no es un paso meramente mecánico, sino una parte crítica de la validez experimental.

En el momento de redactar esta versión, la extracción de los logs seleccionados se encuentra en curso. Los resultados parciales ya superan ampliamente el tamaño de la muestra local utilizada para validar el binario, con decenas de miles de pares módulo-emisor y varios miles de módulos únicos por log. No obstante, estos valores deben considerarse provisionales hasta que finalice la descarga, se reparen los archivos parciales y se reconstruya el conjunto global de módulos únicos.

El resultado final de esta fase será el archivo de entrada utilizado para la ejecución en Altamira. En esa ejecución se registrarán el número total de certificados inspeccionados, el número de módulos RSA extraídos, el número de módulos únicos tras deduplicar, el tiempo de ejecución del algoritmo, el consumo de memoria y, en caso de aparecer, los módulos vulnerables junto con los factores compartidos encontrados.

5.8. Discusión

Los resultados obtenidos permiten extraer varias conclusiones. En primer lugar, la reproducción reducida del experimento de Pelofske confirma la ventaja práctica del algoritmo *Binary Tree Batch GCD* frente al enfoque clásico basado en *remainder tree*. Aunque nuestra parrilla de tamaños es más pequeña que la del artículo original, la tendencia observada es consistente: el algoritmo de árbol binario reduce de forma clara el tiempo de ejecución.

En segundo lugar, la implementación C++/GMP desarrollada en este trabajo mejora de manera notable a las implementaciones Python originales. Esta mejora era esperable por el uso de una biblioteca multiprecisión optimizada y por el mayor control sobre la gestión de memoria, pero los resultados cuantifican su impacto práctico. En los casos más grandes evaluados, la diferencia entre completar el análisis en varios minutos o en pocos segundos es relevante de cara a una futura ejecución sobre conjuntos reales de mayor tamaño.

En tercer lugar, la variación de WEAK muestra que el rendimiento del algoritmo de árbol binario depende en cierta medida del número de factores compartidos presentes en el conjunto. Esto es importante para el problema real, ya que en colecciones de certificados auténticas se espera que los factores compartidos sean eventos poco frecuentes. En ese escenario, precisamente, el algoritmo de Pelofske debería comportarse de forma especialmente favorable.

La principal limitación de esta fase experimental es el tamaño de la parrilla de N y el alcance de la ejecución real local. La reproducción completa de la figura del artículo requeriría alcanzar 75000 módulos para RSA-2048 y 120000 módulos para RSA-1024, además de repetir cada punto para los tres valores de WEAK y, en nuestro caso, para tres implementaciones distintas. Ejecutar esa campaña completa en un portátil no resulta práctico, especialmente por el coste de las implementaciones Python. Del mismo modo, la muestra local de 601 módulos reales sirve para validar el procedimiento, pero no sustituye a la campaña completa sobre los certificados recopilados. Por ello, en este TFM se conserva la estructura experimental del artículo, se valida el flujo con datos reales, se prepara una extracción incremental de módulos desde *CT logs* y se organiza la ejecución masiva sobre el conjunto final en Altamira.

Capítulo 6

Conclusiones y trabajo futuro

En este Trabajo de Fin de Máster se ha estudiado la detección de factores compartidos en claves públicas RSA extraídas de *Certificate Transparency logs*. El punto de partida ha sido una línea de trabajo previa basada en el análisis masivo de certificados, representada principalmente por la tesis de Våge, y una propuesta algorítmica más reciente, el *Binary Tree Batch GCD* de Pelofske.

La primera conclusión del trabajo es que el algoritmo *Binary Tree Batch GCD* constituye una alternativa práctica al enfoque clásico basado en *product tree* y *remainder tree*. La reproducción reducida del experimento de Pelofske confirma que, incluso en un entorno local y con tamaños de entrada menores que los del artículo original, la tendencia es clara: el algoritmo de árbol binario reduce de forma consistente el tiempo de ejecución frente al método clásico.

La segunda conclusión es que la implementación tiene un impacto decisivo. La versión C++17/GMP desarrollada en este TFM mejora de forma muy notable a las implementaciones Python utilizadas como referencia. Esta mejora no se debe únicamente al cambio de lenguaje, sino también a la gestión explícita de los enteros intermedios y a la liberación de memoria durante la construcción del árbol. Para el objetivo aplicado del trabajo, esta diferencia es importante, porque convierte el algoritmo en una herramienta más adecuada para analizar conjuntos reales de certificados.

La tercera conclusión es que el comportamiento observado al variar el número de claves débiles encaja con la motivación del algoritmo. El *Binary Tree Batch GCD* resulta especialmente interesante cuando los factores compartidos son poco frecuentes en comparación con el tamaño total del conjunto. Este escenario es precisamente el esperable en una colección real de certificados: la mayoría de claves deberían ser seguras, y los factores compartidos, si aparecen, deberían ser casos excepcionales.

Además, se ha validado el flujo completo sobre datos reales. La muestra local de certificados procedentes de *CT logs* permitió obtener 601 módulos RSA únicos después de filtrar las claves RSA y eliminar duplicados. Ese conjunto fue procesado correctamente por el binario `batch_gcd_real`. En esa muestra no se detectaron claves vulnerables, pero el resultado principal de esta fase no es la ausencia de factores compartidos, sino la comprobación de que el proceso completo funciona sobre datos reales: extracción de certificados, filtrado de claves RSA, normalización de módulos, eliminación de duplicados y ejecución del algoritmo.

Esa validación local no agota, sin embargo, el objetivo aplicado del trabajo. A partir de ella se ha preparado una campaña de mayor escala basada en módulos extraídos de *ct-archive*. El flujo desarrollado descarga los archivos comprimidos de los logs seleccionados, extrae los certificados presentes en las carpetas `issuer/` o `issuers/`, obtiene de cada uno el módulo RSA y el emisor, y genera tanto una relación `modulo||issuer` como un conjunto deduplicado de módulos para alimentar al binario C++.

La preparación de esta campaña ha puesto de manifiesto que la obtención de módulos reales es una

parte relevante del problema. No basta con disponer del algoritmo: es necesario controlar descargas parciales, revisar archivos marcados erróneamente como carentes de `issuer`/, deduplicar correctamente los módulos y conservar información contextual suficiente para interpretar los resultados. Este proceso convierte la implementación en una herramienta más cercana a una auditoría real sobre *CT logs*.

La ejecución final está preparada para realizarse en Altamira, donde se podrá aprovechar un entorno de cómputo más adecuado que el portátil utilizado para los experimentos locales. Esa ejecución deberá registrar, como mínimo, el número de certificados procesados, el número de módulos RSA válidos, el número de módulos únicos tras eliminar duplicados, el tiempo total de ejecución, el consumo de memoria y, en caso de aparecer, los módulos vulnerables y sus factores compartidos.

Otra línea de mejora consiste en optimizar la segunda fase del algoritmo, en la que los *gcd* no triviales se agregan en la variable *B*. En la implementación actual esta parte se realiza de forma secuencial, lo que es suficiente para la validación realizada, pero podría mejorarse mediante una agregación por árbol o una estrategia paralela si el número de factores compartidos encontrados en un conjunto real fuese elevado.

Finalmente, sería conveniente integrar de forma más sistemática el proceso de extracción y normalización de certificados, de modo que la salida del *pipeline* de *CT logs* pueda alimentar directamente al binario C++ sin pasos manuales intermedios. En esta dirección, el trabajo ya incorpora un flujo incremental de extracción de módulos; una mejora natural sería consolidarlo en una herramienta única, capaz de descargar, validar, deduplicar, ejecutar el ataque y generar un informe final reproducible sobre certificados reales.

Referencias

- N. Heninger, Z. Durumeric, E. Wustrow, y J. A. Halderman. Mining your ps and qs: Detection of widespread weak keys in network devices. In *Proceedings of the 21st USENIX Security Symposium (USENIX Security 12)*, pages 205–220, 2012.
- E. Pelofske. An efficient all-to-all gcd algorithm for low entropy rsa key factorization. *Preprint*, 2024. Independent publication / preprint.
- R. L. Rivest, A. Shamir y L. Adleman. A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM*, 21(2):120–126, 1978.
- H. F. Våge. Finding shared rsa factors in the certificate transparency logs. Master’s thesis, Department of Informatics, University of Bergen, May 2022.